

their respective unique number, but with a false IP address. This results in the client's local cache being updated to this fabricated address. Further damage can be caused by hosting a virus on the machine at that IP address.

DNS rebinding: Also called DNS pinning, this is an advanced type of attack. In this method, the hacker first registers his own domain name and sets the TTL value of that domain at a lower value, which prevents that domain name from being cached.

DNS denial of service: As we learnt in the very first article of this series, bombarding the UDP port 53 or TCP port 53 with DNS queries can cause a DoS attack. Another method is to perform a ping of death or a TCP SYN flood attack. The idea behind this is to overwhelm server resources (CPU and memory) to stop it responding to queries. Though DNS servers are protected by firewalls, if care is not taken to block DNS UDP ports from non-trusted networks, it exposes the name resolution system to this attack.

DNS amplification: Amplification means to provide the DNS server with a task heavier than it is capable of handling. There are multiple ways to stress the server and eventually make it non-functional. In one method of amplification, a Trojan is written to poison and populate the local cache of multiple client hosts. This forces all infected clients to send their name requests to a particular name server, which is being targeted by the hackers. Each server can only respond to a certain number of queries (based on CPU speed and configuration) and eventually starts queuing up requests. As more and more clients get infected, the increasing number of queries ultimately makes the server give up.

In another type of attack, a hacker poisons the DNS server's cache; instead of changing the associated IP address of an A or CNAME record, a change is made to the domain name. To make it worse, the domain name is made to contain a few hundreds or thousands of characters. This starts the replication process, and hence the download of multiple kilobytes of data from the main name server to its replicating partners, and eventually to clients. Upon expiration of the TTL, the replication process initiates again, and results in the breakdown of one or more DNS servers in the chain. This trick actually simulates a distributed denial of service attack, and hence is very dangerous and hard to control.

Protecting FOSS systems

In the FOSS world, the DNS service is a well-known implementation across the globe, simply because it proves to be the fastest available name resolution mechanism. A widely used and famous example is the Linux-based Bind service. However, since most DNS attacks exploit the basic design lacunae, it becomes a tougher task to protect FOSS-based name resolution systems.

The very first step to protect a FOSS DNS server is to lock it down at the network level. Besides the server management ports, only the DNS query ports should be allowed and the rest

must be blocked on the firewall as well as in OS-based port filtering. The second important step is to not install any other software on a DNS server, other than the *name server* service itself. This precaution must be followed especially in the case of an externally facing corporate root name server that holds all internal name spaces, and resolves external name queries for the local area network. It is often found that vulnerability in another program on the name server leaves a back door open, resulting in intrusion into the name service. While most critical infrastructures implement a firewall, a UTM device and powerful anti-virus or anti-Trojan software, it becomes imperative to have an intrusion detection system (IDS) in place. An IDS is capable of filtering out sneaky Layer 2 and Layer 3 attacks such as ARP spoofing, IP spoofing, packet sniffing, etc.

Besides the above crucial precautions, there are a few advanced methods that can be followed too. As we learnt earlier, each query carries its own unique identifier and is marked in the UDP packet. Unfortunately, due to the design of DNS stacks based on RFC standards, these identifiers are easily predictable, and hence randomising those can be a good idea to prevent spoofing attacks. Similarly, the UDP port on which the name server responds is predictable too, and can be randomised. There are open source tools available on the Internet for just this purpose; however, please note that it adds a bit of a delay in query resolution. A fairly recent and popular protection technique is DNSSEC (DNS Security Extensions). It protects clients and systems from cache poisoning attacks by digitally signing records using public key encryption. While working in a similar fashion to SSL, the querying and answering hosts need to establish a digital trust between each other; once it is achieved, name resolution takes place. Once the process is completed, the session is torn down, thus protecting the security at either ends. DNSSEC is being implemented by most ISPs in the world.

DNS invasion is a common phenomenon in the IT security world. It involves exploiting DNS design loopholes to gain access to the IT infrastructure or to lure the client computers to a phishing farm. FOSS is also susceptible to such attacks and hence network administrators must understand the techniques to protect their infrastructure from information loss or theft. 

By: Prashant Phatak

The author has over 18 years of experience in the field of IT hardware, networking, Web technologies and IT security. Prashant is MCSE and MCDBA certified and is also a F5 load balancer expert. In the IT security world he is an ethical hacker and net-forensic specialist. Prashant runs his own firm called Valency Networks in India (www.valencynetworks.com/) providing consultancy in IT security design, security audits, infrastructure technology and business process management. He can be reached at prashant@valencynetworks.com.